
Cuadernillo de Estudio — Clase 7

Seguridad Lógica: Capas, Componentes y el Arsenal de Kali Linux

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	3
2. Seguridad Lógica: El Modelo OSI como mapa de defensa	3
3. Componentes de Seguridad Lógica	4
3.1. Firewall	4
3.2. IDS / IPS	4
3.3. Proxy y Gateway	4
3.4. Zonas de Seguridad: la DMZ	5
3.5. Otros controles lógicos	5
4. Kali Linux: El arsenal del hacker ético	5
4.1. Metapaquetes de Kali	5
5. El Ciclo de Vida del Pentesting y sus Herramientas	6
5.1. Fase 1: Reconocimiento (Information Gathering)	6
5.2. Fase 2: Escaneo y Enumeración	6
5.3. Fase 3: Explotación	7
5.4. Fase 4: Análisis de Tráfico (Sniffing)	7
5.5. Fase 5: Post-Explotación y Reporte	8
6. Ética y Legalidad en el uso de herramientas	8
7. Glosario de conceptos clave	8
8. Autoevaluación	9
9. Respuestas de la Autoevaluación	9
10. Actividad A06: Herramientas de Seguridad Lógica	11

11.Fuentes y bibliografía	12
11.1. Bibliografía obligatoria (según programa)	12
11.2. Bibliografía complementaria (según programa)	12
11.3. Bibliografía específica de Kali y Pentesting	12
11.4. Recursos web y laboratorios	12

1. Objetivos de aprendizaje

Al finalizar la lectura y el trabajo con este cuadernillo, el estudiante será capaz de:

- Analizar el **modelo OSI** desde la perspectiva de la seguridad, identificando vulnerabilidades y controles por capa.
- Identificar y diferenciar los **componentes de seguridad lógica**: Firewalls, IDS/IPS, WAF, Proxies, Antivirus.
- Comprender el diseño de **zonas de seguridad** (DMZ) y el principio de menor privilegio.
- Conocer la distribución **Kali Linux** y su organización en metapaquetes.
- Identificar las **herramientas clave** para cada fase del ciclo de vida del pentesting.
- Preparar la **Actividad A06** investigando herramientas para comprometer la seguridad lógica.

Cómo usar este cuadernillo

Esta clase es el puente entre la teoría de la seguridad (Unidades I-III) y la práctica ofensiva del Hacking Ético (Unidad IV). Aquí conocerás las herramientas que usarás en TryHackMe. Las respuestas de la autoevaluación están en la Sección 9.

2. Seguridad Lógica: El Modelo OSI como mapa de defensa

La seguridad lógica protege los activos de información mediante controles implementados en el software, el hardware y las comunicaciones. Para diseñarla correctamente, usamos el **modelo OSI** como mapa: cada capa tiene sus propias vulnerabilidades y sus propios controles.

Capa	Nombre	Vulnerabilidades típicas	Controles de seguridad
7	Aplicación	Inyección SQL, XSS, APIs inseguras, credenciales débiles	WAF, validación de entradas, HTTPS, OAuth, hardening de apps
6	Presentación	Datos sin cifrar, formatos maliciosos	Cifrado TLS/SSL, firmas digitales
5	Sesión	Secuestro de sesión, fijación de sesión	Gestión segura de sesiones, tokens, timeout
4	Transporte	DoS/DDoS, escaneo de puertos	Firewalls de estado (stateful), filtrado de puertos
3	Red	IP spoofing, suplantación de router, sniffing	ACLs, segmentación (VLANs), firewalls de capa 3, IPsec
2	Enlace	MAC spoofing, ARP poisoning	Port security, DHCP snooping, cifrado de capa 2
1	Física	Interceptación de cable, acceso no autorizado	Cableado protegido, CCTV, controles de acceso físico (Clase 6)

La seguridad por capas

Un atacante puede comprometer una capa (ej. robar credenciales en la capa 7), pero si las capas inferiores están bien diseñadas (segmentación en capa 3, cifrado en capa 6), el impacto se limita. Esto es la **Defensa en Profundidad** aplicada al modelo OSI.

3. Componentes de Seguridad Lógica

3.1. Firewall

Firewall

Dispositivo de red (hardware o software) que controla el tráfico entrante y saliente basándose en reglas de seguridad predefinidas. Actúa como barrera entre redes de distintos niveles de confianza.

Tipos principales:

- **Firewall de filtrado de paquetes:** Analiza cabeceras IP (origen, destino, puerto). Rápido pero limitado.
- **Firewall de estado (stateful):** Rastrea el estado de las conexiones activas. Más inteligente.
- **Firewall de próxima generación (NGFW):** Integra inspección profunda de paquetes (DPI), IDS/IPS y filtrado de aplicaciones.
- **WAF (Web Application Firewall):** Protege específicamente aplicaciones web (filtra tráfico HTTP/HTTPS).

3.2. IDS / IPS

IDS — Intrusion Detection System

Sistema que **monitorea** el tráfico o la actividad del sistema en busca de patrones sospechosos y genera alertas. Es **pasivo**: detecta pero no bloquea.

IPS — Intrusion Prevention System

Evolución del IDS: además de detectar, **bloquea activamente** el tráfico malicioso. Es **activo** y se ubica en línea con el tráfico.

3.3. Proxy y Gateway

- **Proxy:** Intermediario entre el cliente y el servidor. Oculta la identidad interna, filtra contenido y cachea tráfico.
- **Gateway:** Punto de entrada/salida entre redes con distintos protocolos o niveles de confianza.

3.4. Zonas de Seguridad: la DMZ

DMZ — Zona Desmilitarizada

Subred perimetral que aloja los servicios expuestos a Internet (web, mail, DNS). Está separada de la red interna por firewalls. Si un atacante compromete un servidor en la DMZ, no accede directamente a la red interna.

3.5. Otros controles lógicos

- **Políticas de contraseñas:** longitud mínima, complejidad, expiración, bloqueo por intentos fallidos.
- **Gestión de privilegios:** Principio de menor privilegio (cada usuario accede solo a lo necesario para su rol).
- **Certificados digitales:** Garantizan autenticidad e integridad (PKI, CA, X.509).
- **Backup:** Copias de seguridad periódicas, probadas y almacenadas fuera de línea (protección contra ransomware).

4. Kali Linux: El arsenal del hacker ético

Kali Linux

Distribución GNU/Linux basada en Debian, mantenida por Offensive Security, diseñada específicamente para auditorías de seguridad, pentesting, forense digital e investigación. Incluye cientos de herramientas preinstaladas y organizadas por categorías.

¿Por qué Linux y no Windows para pentesting?

- La mayoría de las herramientas de seguridad son nativas de la línea de comandos de Unix/Linux.
- Linux ofrece control total sobre la red (sockets raw, modo promiscuo).
- Es open-source: podés auditar las herramientas que usás.
- Kali es gratuito y se ejecuta en vivo (USB booteable), en máquina virtual o en hardware dedicado.

4.1. Metapaquetes de Kali

Kali organiza sus herramientas en **metapaquetes** temáticos. Los principales son:

- **kali-tools-top10:** Las 10 herramientas más usadas.
- **kali-tools-web:** Herramientas para aplicaciones web (Burp Suite, Nikto, OWASP ZAP).
- **kali-tools-wireless:** Auditoría de redes Wi-Fi (Aircrack-ng, Wifite).
- **kali-tools-exploitation:** Frameworks de explotación (Metasploit).
- **kali-tools-sniffing-spoofing:** Análisis de tráfico (Wireshark, Tcpdump).
- **kali-tools-forensics:** Análisis forense (Autopsy, Sleuth Kit).

5. El Ciclo de Vida del Pentesting y sus Herramientas

Un pentesting profesional sigue una metodología estructurada. Kali provee herramientas para cada fase.

5.1. Fase 1: Reconocimiento (Information Gathering)

Objetivo: Recopilar información pública del objetivo sin interactuar directamente con sus sistemas.

Nmap — Escaneo de redes

- **Función:** Descubrir hosts, puertos abiertos, servicios y sistemas operativos en una red.

- **Ejemplo básico:**

```
1 nmap -sS -p- -A 192.168.1.0/24
```

- **Interpretación:** Escaneo SYN (-sS), todos los puertos (-p-), detección de servicios y SO (-A).

theHarvester — OSINT

- **Función:** Recolectar emails, subdominios y nombres de empleados de un dominio desde fuentes públicas.

- **Ejemplo:**

```
1 theHarvester -d ejemplo.com -b google
```

Otras herramientas de reconocimiento

Whois (información de registro de dominios), Maltego (análisis de relaciones OSINT), DNSdumpster.

5.2. Fase 2: Escaneo y Enumeración

Objetivo: Interactuar con los sistemas descubiertos para identificar vectores de ataque.

Nikto — Escáner de servidores web

- **Función:** Busca vulnerabilidades conocidas en servidores web (archivos peligrosos, versiones desactualizadas, configuraciones erróneas).

- **Ejemplo:**

```
1 nikto -h http://192.168.1.10
```

Netcat — La navaja suiza de TCP/IP

- **Función:** Leer y escribir datos en conexiones de red usando TCP o UDP. Útil para banners, shells reversas y transferencia de archivos.

■ Ejemplo (leer banner):

```
1 nc -v 192.168.1.10 80
```

Otras herramientas de enumeración

Enum4linux (enumeración de recursos Windows/Samba), SNMPwalk, Dirb/Gobuster (fuzzing de directorios web).

5.3. Fase 3: Explotación

Objetivo: Aprovechar las vulnerabilidades identificadas para obtener acceso al sistema.

Metasploit Framework — El estándar de explotación

■ **Función:** Plataforma de desarrollo y ejecución de exploits contra máquinas remotas. Incluye miles de exploits, payloads y módulos auxiliares.

■ **Ejemplo de flujo:**

```
1 msfconsole
2 search vsftpd
3 use exploit/unix/ftp/vsftpd_234_backdoor
4 set RHOSTS 192.168.1.10
5 exploit
```

Searchsploit — Base de datos de exploits offline

■ **Función:** Busca exploits públicos de Exploit-DB directamente desde la terminal.

■ **Ejemplo:**

```
1 searchsploit apache 2.4
```

5.4. Fase 4: Análisis de Tráfico (Sniffing)

Objetivo: Capturar y analizar el tráfico de red para identificar credenciales, protocolos inseguros o anomalías.

Wireshark — Analizador de protocolos

- **Función:** Captura y visualiza paquetes de red en tiempo real. Esencial para entender qué viaja por la red y detectar credenciales en texto plano.
- **Uso:** Se ejecuta desde entorno gráfico o con `tshark` en terminal.

Tcpdump — Captura desde línea de comandos

- **Función:** Captura paquetes sin interfaz gráfica. Ideal para servidores.
- **Ejemplo:**

```
1 tcpdump -i eth0 port 80 -w captura.pcap
```

5.5. Fase 5: Post-Explotación y Reporte

Objetivo: Mantener el acceso, elevar privilegios y documentar los hallazgos.

- **Elevación de privilegios:** Scripts como LinPEAS (Linux) o WinPEAS (Windows) para identificar vías de escalada.
- **Reporte:** La fase más importante del pentesting ético. Sin un informe claro, el trabajo técnico no tiene valor para la organización.

6. Ética y Legalidad en el uso de herramientas

¡Fundamental!

Todas las herramientas de Kali Linux son de **doble uso**: sirven tanto para proteger como para atacar. Su uso está regulado por la ley.

- **Nunca** escanees o explotes un sistema sin autorización escrita.
- Usá siempre **entornos de práctica**: TryHackMe, Hack The Box, máquinas virtuales propias (Metasploitable, VulnHub).
- En la Actividad A06, la investigación es **teórica/descriptiva**: se pide conocer las herramientas, no atacar sistemas reales.

7. Glosario de conceptos clave

Seguridad Lógica	Protección de activos mediante controles de software, hardware y red.
Firewall	Barrera que filtra tráfico según reglas de seguridad.
DMZ	Subred perimetral para servicios expuestos a Internet.
IDS/IPS	Sistemas de detección/prevencción de intrusiones.
WAF	Firewall específico para aplicaciones web.
Pentesting	Prueba de penetración autorizada para evaluar la seguridad.
Exploit	Código o programa que aprovecha una vulnerabilidad.
Payload	Código malicioso que se ejecuta tras la explotación (ej. shell reversa).
OSINT	Inteligencia de fuentes abiertas.
Reconocimiento	Fase de recopilación de información del objetivo.
Sniffing	Captura y análisis de tráfico de red.
Hardening	Proceso de asegurar un sistema reduciendo su superficie de ataque.

8. Autoevaluación

Respondé por escrito; luego verificá en la Sección 9.

1. Elegí dos capas del modelo OSI y, para cada una, identificá una vulnerabilidad típica y un control de seguridad que la mitigue.
2. Diferenciá **Firewall**, **IDS** e **IPS**. ¿Cuál de los tres bloquea activamente el tráfico malicioso?
3. ¿Qué es una **DMZ** y por qué es fundamental en el diseño de redes corporativas?
4. Describí las **5 fases del ciclo de vida del pentesting** y mencioná al menos una herramienta de Kali para cada una.
5. ¿Por qué es importante la fase de **reporte** en un pentesting ético? ¿Qué pasaría si un pentester encuentra una vulnerabilidad crítica pero no la documenta?

9. Respuestas de la Autoevaluación

Nota para el estudiante

Estas respuestas son de referencia. Se valora la precisión técnica y la capacidad de vincular conceptos.

Pregunta 1: Modelo OSI, vulnerabilidades y controles

Respuesta

Dos ejemplos posibles:

▪ Capa 3 (Red):

- **Vulnerabilidad:** IP Spoofing (suplantación de dirección IP para evadir controles de acceso).
- **Control:** Listas de Control de Acceso (ACL) en routers y firewalls de capa 3, o autenticación mediante IPsec.

▪ Capa 7 (Aplicación):

- **Vulnerabilidad:** Inyección SQL (manipulación de consultas a la base de datos a través de formularios web).
- **Control:** Web Application Firewall (WAF) y validación/sanitización de entradas en el código.

Pregunta 2: Firewall vs. IDS vs. IPS

Respuesta

- **Firewall:** Filtra el tráfico según reglas (IP, puerto, protocolo). Es la primera barrera, pero no inspecciona el contenido profundo de los paquetes.
- **IDS (Intrusion Detection System):** Monitorea el tráfico en busca de firmas de ataques o anomalías y **genera alertas**, pero no bloquea. Es pasivo.

- **IPS (Intrusion Prevention System):** Igual que el IDS, pero está ubicado «en línea» con el tráfico y **bloquea activamente** el tráfico malicioso detectado.

El que bloquea activamente es el **IPS**.

Pregunta 3: La DMZ

Respuesta

La **DMZ (Zona Desmilitarizada)** es una subred perimetral que se ubica entre Internet y la red interna de la organización. Aloja los servicios que deben ser accesibles desde afuera (servidores web, mail, DNS). Es fundamental porque:

- **Aísla los servicios expuestos:** Si un atacante compromete el servidor web en la DMZ, no tiene acceso directo a la red interna (archivos, bases de datos internas).
- **Permite un control granular:** El firewall externo deja entrar tráfico solo a la DMZ; el firewall interno solo deja salir tráfico desde la DMZ hacia servicios específicos si es necesario.
- **Facilita el monitoreo:** Todo el tráfico hacia/desde Internet pasa por un punto controlado.

Pregunta 4: Fases del pentesting y herramientas Kali

Respuesta

1. **Reconocimiento:** Recopilar información pública. **Herramienta:** theHarvester, Whois, Maltego.
2. **Escaneo / Enumeración:** Descubrir hosts, puertos y servicios. **Herramienta:** Nmap, Nikto, Netcat.
3. **Explotación:** Aprovechar vulnerabilidades para obtener acceso. **Herramienta:** Metasploit Framework, Searchsploit.
4. **Post-Explotación:** Mantener acceso, elevar privilegios, moverse lateralmente. **Herramienta:** LinPEAS, WinPEAS, Netcat (shell reversa).
5. **Reporte:** Documentar hallazgos y recomendar mitigaciones. **Herramienta:** Editores de informes, plantillas de la cátedra.

Pregunta 5: Importancia del reporte

Respuesta

El reporte es la fase más importante porque **traduce el trabajo técnico en valor de negocio**:

- Informa a la dirección **qué riesgos reales** existen y **cuánto cuesta** mitigarlos.
- Permite priorizar la inversión en seguridad.

- Sirve como evidencia para auditorías y cumplimiento normativo.

Si un pentester encuentra una vulnerabilidad crítica y no la documenta:

- El cliente **no puede corregirla**.
- El atacante real la explotará eventualmente.
- El pentester incumple su contrato y, dependiendo del marco legal, podría ser responsable por omisión.
- La confianza en el profesional se destruye.

10. Actividad A06: Herramientas de Seguridad Lógica

Consigna A06 — Seguridad Lógica: Herramientas para conocer vulnerabilidades

Metodología: Trabajo de Investigación. **Consigna:** Obtener información acerca de herramientas que puedan utilizarse para comprometer la seguridad lógica. Compartir la experiencia. **Entregable:**

1. Elegir **3 herramientas** de Kali Linux (o alternativas gratuitas) de categorías distintas (ej. una de reconocimiento, una de explotación, una de análisis de tráfico).
2. Para cada una, investigar y documentar:
 - ¿Qué hace y en qué fase del pentesting se usa?
 - ¿Qué comandos o parámetros básicos tiene?
 - ¿Qué vulnerabilidad o debilidad permite detectar o explotar?
 - ¿Qué salvaguarda mitiga el riesgo que la herramienta explota?
3. Redactar una reflexión ética sobre el uso responsable de estas herramientas.

Subilo a la carpeta del Trabajo Integrador en Google Drive, otorgando permisos de comentario a era.profe@gmail.com.

Rúbrica de evaluación (según grilla de la cátedra):

Criterio	Peso	Qué se espera para el «Excelente» (4)
A. Recopilación de información	50 %	Utiliza de manera completa fuentes confiables (documentación oficial de Kali, man pages, libros de pentesting) y las cita correctamente.
B. Elaboración de documentos	20 %	Cumple adecuadamente con los formatos atento a la planilla de estandarización brindada por la cátedra.
C. Elaboración de presentaciones	10 %	Argumenta de manera sólida el inconveniente del caso y su solución.
F. Consciencia de buenas prácticas	20 %	Evidencia permanentemente el respeto por los límites éticos y legales en la descripción de las herramientas.

11. Fuentes y bibliografía

11.1. Bibliografía obligatoria (según programa)

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Elgueta, R. (s.f.). *Guías de Clase unidad III*. Material inédito. UCH.

11.2. Bibliografía complementaria (según programa)

- Bancal, D. (2022). *Seguridad informática* (5.^a ed.). Ediciones ENI.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing to Audit and Improve the Cybersecurity of Computer Networks for Beginners, Including Tips on Social Engineering*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.
- ISO/IEC (2005). *Information security management 27001*.

11.3. Bibliografía específica de Kali y Pentesting

- Offensive Security. *Kali Linux Revealed: Mastering the Penetration Testing Distribution*.
- Georgia Weidman. (2014). *Penetration Testing: A Hands-On Introduction to Hacking*. No Starch Press.
- Patrick Engebretson. (2013). *The Basics of Hacking and Penetration Testing*. Syngress.

11.4. Recursos web y laboratorios

- Documentación oficial de Kali Linux: <https://www.kali.org/docs/>
- TryHackMe (laboratorio oficial de la materia): <https://tryhackme.com>
- OWASP Top 10: <https://owasp.org/www-project-top-ten/>
- Nmap Reference Guide: <https://nmap.org/book/man.html>
- Metasploit Documentation: <https://docs.metasploit.com/>